

Security+ 1.4 · Hashing & Digital Signatures

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 1.4 — Hashing & Digital Signatures (10:24)** · [Vídeo no YouTube ↗](#)

Resumo da Aula: Hash = impressão digital mão única: SHA-256/SHA-3 padrão; MD5/SHA-1 quebrados. Assinatura digital = cifrar o hash com a chave PRIVADA — qualquer um valida com a pública. Garante integridade + autenticidade + non-repudiation (3 objetivos).

Highlights que a prova cobra

- SHA-256 padrão; MD5/SHA-1 quebrados (collision)
- Assinatura = hash cifrado com chave PRIVADA de quem assina
- Avalanche effect: 1 bit mudou = hash inteiro mudou

Dicas de prova & Cenários Típicos

- 'provides integrity but not confidentiality' = hash
- 'cannot deny that they signed' = digital signature (non-repudiation)

Cenário clássico de exame: Cenário: 'arquivo é verificado com SHA-256 depois do download pra confiar que não foi alterado' = integridade por hash.

🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Seção 1.4)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer (Hashing & Digital Signatures) resume os conceitos de forma ágil. Contudo, a banca examinadora oficial da CompTIA (SY0-701) exige raciocínio prático de engenharia de segurança, diferenciação entre protocolos concorrentes e aplicação em cenários corporativos reais. Entenda os conceitos complementares fundamentais:

- **Criptografia Simétrica (AES-256, ChaCha20):** Usa uma única chave idêntica para cifrar e decifrar. Excelente para confidencialidade de grandes volumes (BitLocker, banco de dados, túneis VPN). **Atenção de prova:** cifras simétricas NÃO oferecem não-repúdio quando a chave é compartilhada.
- **Criptografia Assimétrica (RSA, ECC, Ed25519):** Usa par de chaves matemáticas: a Chave Pública é distribuída livremente; a Chave Privada é mantida em segredo absoluto pelo titular. Assinar o hash com a chave privada garante **Não-repúdio e Autenticidade**. Cifrar com a chave pública do destinatário garante **Confidencialidade**.
- **Hashing (SHA-256, SHA-3) vs. HMAC:** Hash puro é função matemática unidirecional sem chave, garantindo apenas integridade (qualquer um pode recalculá-lo de um dado adulterado). O HMAC combina hash com chave simétrica secreta, provendo integridade e autenticação mútua entre sistemas conhecidos.
- **TSA (Time Stamping Authority - RFC 3161) e LTV:** Entidade confiável que assina o hash com data/hora auditada, provando o momento exato em que o documento existiu e garantindo validação de longo prazo (LTV) mesmo após a expiração de certificados.

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Hash puro NÃO fornece não-repúdio.
- AES com chave compartilhada destrói o não-repúdio.
- Políticas em papel e termos de adesão são controles puramente administrativos; não bloqueiam ataques em tempo de execução.

✅ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise dos distratores no fim. Tente responder antes de olhar.

1. Pra garantir que um arquivo NÃO foi alterado (integridade), tu usa:

- A)** Compressão ZIP
- B)** Função hash (ex: SHA-256)
- C)** Criptografia AES
- D)** Assinatura Base64

2. Uma característica de HASH (diferente de criptografia) é que ele:

- A)** Pode ser revertido com a chave
- B)** É de mão única (não reversível)
- C)** Sempre encurta o texto pela metade
- D)** Precisa de par de chaves

3. A forma correta de ARMAZENAR senhas de usuários:

- A)** Hash com salt (ex: bcrypt)
- B)** Criptografia AES reversível
- C)** Texto claro protegido por firewall
- D)** Base64

4. Qual função criptográfica NÃO é reversível?

- A)** Criptografia AES
- B)** Criptografia RSA
- C)** Hash SHA-256
- D)** Codificação Base64

5. Cenário corporativo (Hashing & Digital Signatures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'SHA-256 padrão; MD5/SHA-1 quebrados (collision)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: SHA-256 padrão; MD5/SHA-1 quebrados (collision)...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Hashing & Digital Signatures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'Assinatura = hash cifrado com chave PRIVADA de quem assina'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Assinatura = hash cifrado com chave PRIVADA de quem assina...

7. Cenário corporativo (Hashing & Digital Signatures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'Avalanche effect: 1 bit mudou = hash inteiro mudou'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Avalanche effect: 1 bit mudou = hash inteiro mudou...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Hashing & Digital Signatures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: '"provides integrity but not confidentiality' = hash'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'provides integrity but not confidentiality' = hash...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Hashing & Digital Signatures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: "cannot deny that they signed" = digital signature (non-repudiation). Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'cannot deny that they signed' = digital signature (non-repudiation)...

10. Cenário corporativo (Hashing & Digital Signatures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'Cenário: 'arquivo é verificado com SHA-256 depois do download pra confiar que não foi alterado' = integridade por hash.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Cenário: 'arquivo é verificado com SHA-256 depois do download pra confiar q...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

1) B — Função hash (ex: SHA-256).

✓ **Por que está certa:** Hash gera uma 'impressão digital'; se um bit muda, o hash muda. SHA-256 é padrão. AES dá confidencialidade, não integridade por si só.

✗ **Por que as outras estão erradas:**

- *Compressão ZIP:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Criptografia AES:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Assinatura Base64:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

2) B — É de mão única (não reversível).

✓ **Por que está certa:** Hash é one-way: não dá pra 'descriptografar' de volta. Por isso serve pra guardar senha (compara hashes) e checar integridade.

✗ **Por que as outras estão erradas:**

- *Pode ser revertido com a chave:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Sempre encurta o texto pela metade:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Precisa de par de chaves:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

3) A — Hash com salt (ex: bcrypt).

✓ **Por que está certa:** Senha se guarda como HASH salgado (bcrypt/argon2) — não reversível. Nunca em texto claro nem cripto reversível (a chave vaza junto).

✗ **Por que as outras estão erradas:**

- *Criptografia AES reversível:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Texto claro protegido por firewall:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Base64:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

4) C — Hash SHA-256.

✓ **Por que está certa:** Hash (SHA-256, MD5) é função unidirecional (one-way) - não pode ser revertida para recuperar o dado original. Criptografias são reversíveis com a chave correta.

✗ **Por que as outras estão erradas:**

- *Criptografia AES:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Criptografia RSA:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Codificação Base64:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

5) A — Implementar a solução correspondente: SHA-256 padrão; MD5/SHA-1 quebrados (collision)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Hashing & Digital Signatures): SHA-256 padrão; MD5/SHA-1 quebrados (collision).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) D — Implementar a solução correspondente: Assinatura = hash cifrado com chave PRIVADA de quem assina....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Hashing & Digital Signatures): Assinatura = hash cifrado com chave PRIVADA de quem assina.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) B — Implementar a solução correspondente: Avalanche effect: 1 bit mudou = hash inteiro mudou....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Hashing & Digital Signatures): Avalanche effect: 1 bit mudou = hash inteiro mudou.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) B — Implementar a solução correspondente: 'provides integrity but not confidentiality' = hash....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Hashing & Digital Signatures): 'provides integrity but not confidentiality' = hash.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) D — Implementar a solução correspondente: 'cannot deny that they signed' = digital signature (non-repudiation)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Hashing & Digital Signatures): 'cannot deny that they signed' = digital signature (non-repudiation).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) C — Implementar a solução correspondente: Cenário: 'arquivo é verificado com SHA-256 depois do download pra confiar q....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Hashing & Digital Signatures): Cenário: 'arquivo é verificado com SHA-256 depois do download pra confiar que não foi alterado' = integridade por hash..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

